

Security+ 4.4 · Security Tools

Mestre CyberSec · Aula 4.4 — Security Tools (14:06) · [Assistir Vídeo no YouTube ↗](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: SCAP (Security Content Automation Protocol): padrão pra automatizar compliance (NIST 800-53/CIS). SIEM, SOAR, vulnerability scanner, FIM, EDR — cada uma cobre uma etapa.

💡 Highlights que a prova CompTIA cobra

- SIEM detecta; SOAR AGE; EDR isola; FIM checa arquivo
- SCAP: automatiza o compliance check

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'automates security compliance checks'=SCAP/OpenSCAP

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Protocolo de Automação de Conteúdo de Segurança (SCAP)

Security Content Automation Protocol é um conjunto de especificações para automatizar gestão de vulnerabilidades, medição e avaliação de conformidade de políticas com padrões como NIST 800-53 e CIS Benchmarks.

⚠ **Armadilha CompTIA:** Se a questão pedir 'automatiza checagens de conformidade de segurança' ou 'compliance automatizado', marque SCAP/OpenSCAP. Não confunda com SIEM, que apenas correlaciona logs.

• OpenSCAP

OpenSCAP é uma implementação open-source do SCAP usada para escanear sistemas quanto à conformidade com baselines de segurança e gerar orientação de remediação.

⚠ **Armadilha CompTIA:** OpenSCAP = ferramenta que aplica SCAP. Gatilho: 'SCAP compliance scan' ou 'baseline automatizada'.

• Gerenciamento de Informações e Eventos de Segurança (SIEM)

Security Information and Event Management coleta e correlaciona logs e eventos de várias fontes para detectar ameaças e apoiar relatórios de conformidade.

⚠ **Armadilha CompTIA:** SIEM detecta e correlaciona; não age automaticamente. Se a questão falar em orquestrar resposta, pense SOAR.

• Orquestração, Automação e Resposta de Segurança (SOAR)

Security Orchestration, Automation, and Response integra ferramentas e automatiza fluxos de resposta a incidentes, como enriquecimento, contenção e remediação.

⚠ **Armadilha CompTIA:** SOAR AGE. Se o cenário pede automatizar playbooks ou resposta a incidentes, marque SOAR, não SIEM.

• Scanner de Vulnerabilidades (N/A)

Um scanner de vulnerabilidades identifica fraquezas conhecidas, patches ausentes e más configurações em hosts, aplicações e redes.

⚠ **Armadilha CompTIA:** Scanner identifica vulnerabilidades, mas não necessariamente explora ou corrige. Ele alimenta SIEM/SOAR e gestão de vulnerabilidades.

• Monitoramento de Integridade de Arquivos (FIM)

File Integrity Monitoring detecta alterações não autorizadas em arquivos críticos comparando hashes ou baselines ao longo do tempo.

⚠ **Armadilha CompTIA:** FIM checa arquivo/hash. Gatilho: 'alteração não autorizada em arquivo de sistema' ou 'baseline de integridade'.

• Detecção e Resposta em Endpoint (EDR)

Endpoint Detection and Response monitora continuamente endpoints, detecta comportamento malicioso e pode isolar ou remediar hosts comprometidos.

⚠ **Armadilha CompTIA:** EDR isola endpoint. Se a questão pede contenção em host/endpoint, marque EDR; se é log central, SIEM; se é automação de playbook, SOAR.

• Benchmarks CIS

CIS Benchmarks são diretrizes de configuração de segurança baseadas em consenso usadas para hardening de sistemas e verificação de conformidade.

⚠ **Armadilha CompTIA:** SCAP/OpenSCAP pode avaliar conformidade com CIS Benchmarks. Não confunda benchmark de configuração com scanner de vulnerabilidades.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma organização de saúde sujeita à HIPAA precisa demonstrar conformidade técnica contínua com os controles do NIST SP 800-53 em mais de 800 servidores Linux e Windows. O CISO deseja uma estrutura padronizada e legível por máquina que suporte linhas de base automatizadas, enumeração de vulnerabilidades e relatórios para alimentar diretamente o painel de GRC. Qual tecnologia o arquiteto deve recomendar?

- A) Security Orchestration, Automation, and Response (SOAR)
- B) Security Content Automation Protocol (SCAP)
- C) Endpoint Detection and Response (EDR)
- D) File Integrity Monitoring (FIM)

QUESTÃO 2 · CENÁRIO DE EXAME

Após uma fusão, a nova empresa recebe mais de 12 bilhões de eventos por dia de firewalls, switches EDR, controladores de domínio, proxies web e logs de SaaS em nuvem. O gerente do SOC precisa de uma solução que ingira esses fluxos heterogêneos, normalize-os em um esquema comum, correlacione-os para detectar ataques em múltiplas etapas e os retenha por um ano para análise forense. Qual classe de ferramenta é necessária?

- A) Vulnerability Scanner
- B) File Integrity Monitoring (FIM)
- C) Security Information and Event Management (SIEM)
- D) Endpoint Detection and Response (EDR)

QUESTÃO 3 · CENÁRIO DE EXAME

Analistas de SOC de Nível 1 gastam 70% do turno triando manualmente os mesmos cinco alertas recorrentes: submissões de phishing, tentativas de força bruta SSH, detecções de malware e execuções suspeitas de PowerShell. O diretor do SOC quer implantar playbooks automatizados que consultem threat intel, enriqueçam dados, isolem endpoint, bloqueiem IPs adicionais e fechem falsos positivos confirmados — tudo sem aprovação humana. Qual tecnologia atende a esse requisito?

- A) Security Orchestration, Automation, and Response (SOAR)
- B) Security Content Automation Protocol (SCAP)
- C) File Integrity Monitoring (FIM)
- D) Vulnerability Scanner

QUESTÃO 4 · CENÁRIO DE EXAME

Seis semanas antes da auditoria externa anual, o gerente de vulnerabilidades deve produzir um relatório listando cada patch ausente, versão de software sem suporte e CVE exposto em 4.500 endpoints e 1.200 servidores. A auditoria exige varredura autenticada com comprovação e uma lista de remediação priorizada por CVSS. Qual ferramenta a equipe deve implantar?

- A) Endpoint Detection and Response (EDR)
- B) File Integrity Monitoring (FIM)
- C) Security Information and Event Management (SIEM)
- D) Vulnerability Scanner

QUESTÃO 5 · CENÁRIO DE EXAME

Após um incidente no qual atacantes substituíram silenciosamente o binário de um serviço legítimo do sistema por uma versão com backdoor em um servidor de processamento de pagamentos, a equipe de conformidade precisa de um controle automatizado que calcule linhas de base criptográficas de arquivos do sistema operacional e de aplicações em repouso, e acione uma violação imediata quando qualquer arquivo monitorado for alterado, adicionado ou removido. Qual tecnologia deve ser implantada?

- A)** Security Information and Event Management (SIEM)
- B)** Vulnerability Scanner
- C)** File Integrity Monitoring (FIM)
- D)** Security Orchestration, Automation, and Response (SOAR)

QUESTÃO 6 · CENÁRIO DE EXAME

Caçadores de ameaças descobrem que um agente malicioso financeiramente motivado está usando malware sem arquivo, binários living-off-the-land (LOLBins) e ferramentas de roubo de credenciais que contornam o antivírus baseado em assinatura legado nos laptops da diretoria. A equipe precisa de uma solução que registre árvores de processos, conexões de rede e comportamento de memória em nível de kernel, possa isolar um laptop comprometido remotamente e suporte regras YARA personalizadas. Qual classe de ferramenta é necessária?

- A)** File Integrity Monitoring (FIM)
- B)** Vulnerability Scanner
- C)** Endpoint Detection and Response (EDR)
- D)** Security Content Automation Protocol (SCAP)

QUESTÃO 7 · CENÁRIO DE EXAME

O novo CISO determina que todo sistema operacional, banco de dados e dispositivo de rede na organização deve ser fortalecido de acordo com um conjunto de recomendações prescritivas, validadas pela comunidade, consensuais e neutras em relação ao fornecedor — cobrindo políticas de senha, configurações de auditoria, serviços e valores de registro — antes de ser conectado à produção. Qual recurso a equipe de engenharia deve consultar?

- A)** CIS Benchmarks
- B)** Security Content Automation Protocol (SCAP)
- C)** Security Information and Event Management (SIEM)
- D)** Security Orchestration, Automation, and Response (SOAR)

QUESTÃO 8 · CENÁRIO DE EXAME

Uma equipe de TI universitária com restrição orçamentária precisa automatizar a varredura de conformidade de servidores Red Hat Enterprise Linux contra DISA STIGs e perfis CIS usando conteúdo no formato SCAP (XCCDF/OVAL). Eles não podem pagar ferramentas comerciais e precisam de um scanner gratuito e de código aberto que suporte datastreams SCAP. Qual tecnologia devem adotar?

- A)** Endpoint Detection and Response (EDR)
- B)** Security Information and Event Management (SIEM)
- C)** Vulnerability Scanner
- D)** OpenSCAP

QUESTÃO 9 · CENÁRIO DE EXAME

O SOC está inundado de alertas de várias fontes — e-mails de phishing reportados por usuários, detecções de malware do EDR e anomalias de autenticação do SIEM. O gerente de operações quer uma plataforma que não apenas centralize casos, mas também extraia automaticamente IOCs de e-mails recebidos, consulte o VirusTotal e o threat intel interno, bloqueie remetentes no gateway de e-mail, abra um ticket no ServiceNow e notifique o analista — tudo em segundos. Qual capacidade está sendo descrita?

- A)** Security Information and Event Management (SIEM)
- B)** Endpoint Detection and Response (EDR)
- C)** Security Orchestration, Automation, and Response (SOAR)
- D)** File Integrity Monitoring (FIM)

QUESTÃO 10 · CENÁRIO DE EXAME

Uma investigação interna revela que os atacantes exfiltraram dados após adulterar os arquivos de configuração de uma conta de serviço privilegiada em vários controladores de domínio. O CISO pós-incidente quer uma solução dedicada e leve que rode continuamente em cada servidor, capture hashes criptográficos de arquivos e chaves de registro protegidos, e encaminhe eventos de adulteração ao SIEM — sem realizar análise comportamental ou resposta em endpoint. Qual classe de ferramenta melhor se encaixa?

- A)** Vulnerability Scanner
- B)** File Integrity Monitoring (FIM)
- C)** Security Information and Event Management (SIEM)
- D)** Security Content Automation Protocol (SCAP)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Security Content Automation Protocol (SCAP)

O SCAP é o conjunto padronizado de protocolos (XCCDF, OVAL, CPE, CVE, CVSS, CCSS) que permite automatizar a gestão de vulnerabilidades, avaliação de conformidade de políticas e pontuação contra linhas de base do NIST 800-53. O SOAR orquestra ações de resposta, o EDR foca no comportamento de endpoints e o FIM detecta alterações em arquivos — nenhum desses fornece o conteúdo de conformidade legível por máquina que o SCAP oferece.

Questão 2: Alternativa C — Security Information and Event Management (SIEM)

Um SIEM é projetado exatamente para esse propósito: agregação central de logs, normalização de fontes distintas, regras de correlação em tempo real para detectar cadeias de ataque e retenção de longo prazo para casos de uso forenses e de conformidade. Scanners de vulnerabilidade procuram fraquezas, o FIM detecta alterações em arquivos e o EDR foca na telemetria de endpoints, não na correlação em toda a empresa.

Questão 3: Alternativa A — Security Orchestration, Automation, and Response (SOAR)

Plataformas SOAR fornecem gestão de casos, integração com threat intel e automação visual de runbooks que orquestram ações entre várias ferramentas de segurança (EDR, firewall, ticketing, TIP). São projetadas para eliminar trabalho manual repetitivo. O SCAP é para conteúdo de conformidade, o FIM monitora arquivos e o scanner de vulnerabilidade encontra fraquezas — nenhum deles automatiza fluxos de resposta multi-ferramenta.

Questão 4: Alternativa D — Vulnerability Scanner

Um scanner de vulnerabilidades autenticado (ex.: Nessus, Qualys, Rapid7) realiza verificações autenticadas, identifica patches ausentes, softwares desatualizados e CVEs conhecidos, e produz relatórios priorizados por CVSS — exatamente o que a auditoria exige. O EDR foca em ameaças em tempo de execução, o FIM monitora alterações em arquivos e o SIEM correlaciona eventos; nenhum gera inventário de patches.

Questão 5: Alternativa C — File Integrity Monitoring (FIM)

Ferramentas FIM (ex.: OSSEC, Tripwire, AIDE) calculam linhas de base criptográficas (hashes MD5/SHA) de arquivos e comparam continuamente o estado atual com essa linha de base para detectar modificações, adições ou exclusões não autorizadas — exatamente o cenário descrito. O SIEM correlaciona eventos, mas não mantém linhas de base de arquivos; o scanner de vulnerabilidade procura patches ausentes e o FIM automatiza resposta, não detecção de integridade.

Questão 6: Alternativa C — Endpoint Detection and Response (EDR)

Soluções EDR (ex.: CrowdStrike, SentinelOne, Microsoft Defender for Endpoint) registram telemetria rica de endpoints, detectam indicadores comportamentais de ataque (LOLBins, dumping de credenciais, injeção de processo), permitem isolamento remoto do host e suportam regras de detecção personalizadas como YARA. O FIM apenas monitora integridade de arquivos, scanners de vulnerabilidade procuram fraquezas e o SCAP é uma estrutura de conformidade — nenhum fornece detecção comportamental e contenção remota.

Questão 7: Alternativa A — CIS Benchmarks

Os CIS Benchmarks são guias de hardening consensuais, neutros em relação ao fornecedor, que fornecem recomendações prescritivas passo a passo (chaves de registro específicas, tamanhos de senha, políticas de auditoria) para sistemas operacionais, aplicações e dispositivos de rede. São a linha de base de hardening de fato, referenciada por auditores e estruturas de conformidade. O SCAP é o protocolo para conteúdo legível por máquina, o SIEM agrega eventos e o FIM orquestra resposta — nenhum é um guia de hardening.

Questão 8: Alternativa D — OpenSCAP

OpenSCAP é a implementação de código aberto do SCAP que suporta datastreams XCCDF/OVAL, avalia sistemas contra DISA STIGs, perfis CIS e linhas de base do NIST, e é incluído com o Red Hat Enterprise Linux. EDR, SIEM e scanners de vulnerabilidade comerciais não são scanners SCAP de código aberto gratuitos; OpenSCAP é a resposta canônica para esse requisito.

Questão 9: Alternativa C — Security Orchestration, Automation, and Response (SOAR)

SOAR é a plataforma que integra com gateways de e-mail, feeds de threat intel, sistemas de ticket e EDR para executar playbooks automatizados em várias ferramentas. Combina gestão de casos, orquestração e ações de resposta automatizadas.

O SIEM foca em agregação e correlação de logs, o EDR detecta ameaças em endpoints e o FIM monitora arquivos — nenhum orquestra fluxos multi-ferramenta automatizados.

Questão 10: Alternativa B — File Integrity Monitoring (FIM)

O FIM é projetado exatamente para isso: cria linhas de base criptográficas de arquivos/chaves de registro selecionados, roda como um agente leve baseado em host, detecta modificações/adições/ exclusões e envia violações de integridade ao SIEM. Não realiza varredura de vulnerabilidades, análise comportamental ou ações de resposta, mas foca exclusivamente em detectar alterações não autorizadas em artefatos monitorados.